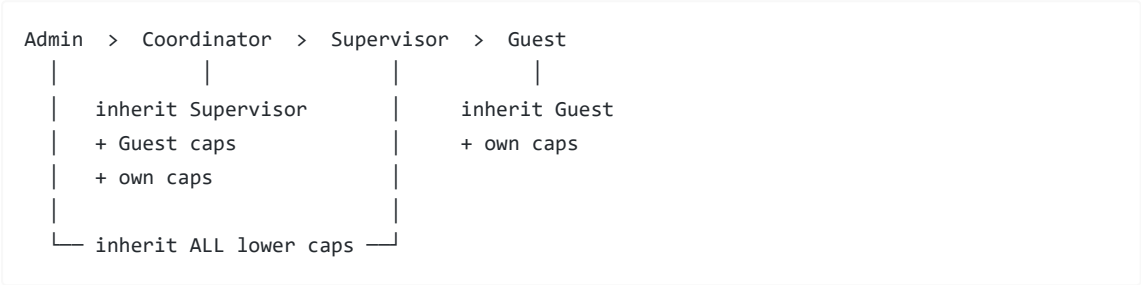


PBAC Matrix — Inspect-able

Policy-Based Access Control. Roles define administrative scope; Qualifications grant operational inspection authority. The engine unions capabilities from both.

1. Role Hierarchy



Higher roles inherit **all** capabilities of lower roles. You never need multiple roles like `Coordinator + Supervisor`.

2. Administrative Role → Capability Matrix

Capability	Guest	Supervisor	Coordinator	Admin
view:dashboard	✓	✓ (inherited)	✓ (inherited)	✓ (inherited)
manage:locations	—	✓ (dept-scoped)	✓ (inherited)	✓
schedule:manage_dept	—	✓	✓ (inherited)	✓ (inherited; covered by schedule:manage_all)
schedule:manage_all	—	—	—	✓
assign:others	—	—	—	✓ (Admin only; COI makes same-dept Coordinator assignment impossible)
view:all_departments	—	—	✓	✓ (inherited)
manage:departments	—	—	✓ (dept-scoped)	✓
manage:users	—	—	✓ (dept-scoped)	✓
manage:groups	—	—	✓	✓ (inherited)
manage:mappings	—	—	✓	✓ (inherited)
manage:kpi	—	—	—	✓
manage:phases	—	—	—	✓
manage:permissions	—	—	—	✓

manage:settings	—	—	—	✓
manage:certs	—	—	—	✓
purge:data	—	—	—	✓
system:admin	—	—	—	✓
system:reset	—	—	—	✓

3. Inspector Activation

Trigger	Condition	Capabilities Granted
Valid Certificate	certificationExpiry is present and $\geq$ today (org timezone)	asset_inspector, assign:self

Note: Inspector is not a role. A valid certificate IS the inspector qualification. No separate `qualifications[]` entry needed. Any user with any role becomes an active inspector when their certificate is valid.

4. Role + Qualification → Combined Capabilities

Administrative Role	Qualification	Combined Capabilities (Union)
Admin	—	Full system administration
Admin	Inspector	Full admin + asset_inspector, assign:self
Coordinator	—	Manage own department logistics (schedules, users, locations, groups, mappings). Cannot assign inspectors (COI deadlock).
Coordinator	Inspector	Dept management + self-assign to cross-dept audits
Supervisor	—	Manage only locations they supervise (dates, lock/unlock). View own dept schedules.
Supervisor	Inspector	Supervised locations + self-assign cross-dept as inspector. Can pick dates anywhere; change/unlock only on supervised or assigned audits.
Guest	—	View dashboard only
Guest	Inspector	Dashboard view + self-assign as inspector. Can pick dates anywhere; change/unlock only on assigned audits.

Design principle: Never store `Coordinator + Inspector` as a role. Store `{ role: "Coordinator" }`. `Inspector` is derived from a valid `certificationExpiry`, NOT from `qualifications[]`. The policy engine unions role capabilities + certificate-derived capabilities.

5. Action → Policy Mapping

5.1 Audit Schedule Actions

Action	Policies Applied	Who Can Perform
schedule.assign	CAN_SELF_ASSIGN	Users with asset_inspector + assign:self
schedule.unassign	SLOT_OWNER_OR_PRIVILEGED	Slot owner or privileged role
schedule.lock	(schedule:manage_dept OR schedule:manage_all) + per-role scope	Supervisor (own locations), Coordinator (own dept), Admin (all)
schedule.set_date (pick)	REQUIRE_ACTIVE_INSPECTOR + DATE_WITHIN_PHASE	Active inspector: first-time date pick on any audit (phase checked, COI NOT checked at pick time — COI is checked at assignment)
schedule.set_date (change)	schedule:manage_dept + DATE_WITHIN_PHASE + per-role scope	Supervisor (own locations), Coordinator (own dept), Inspector (assigned audits), Admin (all)
schedule.set_status	(schedule:manage_dept OR schedule:manage_all) + VALID_STATUS_TRANSITION	Supervisor / Admin
schedule.upload_report	ASSIGNED_AUDITOR_ONLY + REQUIRE_ACTIVE_INSPECTOR	Assigned auditor (certificate must be valid at upload time)

5.2 Audit CRUD

Action	Policies Applied
audit.create	system:admin
audit.delete	system:admin
audit.maintenance	manage:departments + COORDINATOR_DEPT_SCOPE

5.3 User Management

Action	Policies Applied
user.create	manage:users + COORDINATOR_DEPT_SCOPE
user.update	Self-update OR manage:users
user.delete	manage:users
user.verify	manage:users
user.certify	manage:certs (Admin only)

5.4 Administration

Action	Required Capability
admin.manage	system:admin

department.manage	manage:departments
location.manage	manage:locations
group.manage	manage:groups
kpi.manage	manage:kpi
phase.manage	manage:phases
permission.manage	manage:permissions
mapping.manage	manage:mappings
system.settings	manage:settings
system.reset	system:reset
data.purge	purge:data

6. CanInspectAudit — Inspection Eligibility Rules

These five policies together define who is eligible to be assigned as an inspector:

CanInspectAudit:

- 1. certificate is valid (not expired) → REQUIRE_ACTIVE_INSPECTOR
- 2. audit.department != user.department → STRICT_COI
- 3. user is not the site supervisor of this loc → NO_SUPERVISOR_CONFLICT
- 4. schedule date falls within any configured phase → DATE_WITHIN_PHASE
- 5. location not already inspected in scheduleDate year → NO_ANNUAL_CONFLICT

#	Policy	Denial Reason Code	Denial Message
1	REQUIRE_ACTIVE_INSPECTOR	CERT_EXPIRED	<i>Your Inspector certificate is expired or invalid.</i>
2	STRICT_COI	COI_VIOLATION	<i>You cannot audit your own department.</i>
3	NO_SUPERVISOR_CONFLICT	SUPERVISOR_CONFLICT	<i>You are a Site Supervisor for this location and cannot act as its inspector.</i>
4	DATE_WITHIN_PHASE	DATE_OUTSIDE_PHASE	<i>The scheduled date does not fall within any configured audit phase.</i>
5	NO_ANNUAL_CONFLICT	LOCATION_YEAR_CONFLICT	<i>This location is already scheduled to be inspected in the calendar year of the scheduled date.</i>

STRICT_COI has no exemptions — not even for Admins. It is an absolute institutional integrity rule.

7. Policy Definitions Reference

Core Policies

Policy	Type	Description
REQUIRE_ACTIVE_INSPECTOR	Certificate gate	certificationExpiry must be present and $\geq$ current date in the organization's timezone (Asia/Kuala_Lumpur). A valid certificate IS the inspector qualification — no separate qualifications[] entry needed.
STRICT_COI	Integrity rule	user.departmentId $\neq$ targetDepartmentId — no exemptions
NO_SUPERVISOR_CONFLICT	Integrity rule	User must not be listed as supervisor for the target location
DATE_WITHIN_PHASE	Phase scheduling rule	If scheduleDate is null and status is Pending, allow. If scheduleDate is present, it must fall within any configured audit phase (Phase 1, 2, or 3). If present but outside all phases, deny with DATE_OUTSIDE_PHASE.
NO_ANNUAL_CONFLICT	Scheduling rule	Location must not have an active or completed inspection in the calendar year of scheduleDate; cancelled/deleted schedules are ignored. When updating an existing schedule, the current record's own scheduleId/auditId is excluded from the conflict check
NO_DOUBLE_BOOKING	Concurrency gate	Schedule slot must be 'open'

Composite Policies

Composite	Constituent Policies	Used By
CAN_INSPECT_AUDIT_POLICIES	REQUIRE_ACTIVE_INSPECTOR + STRICT_COI + NO_SUPERVISOR_CONFLICT + DATE_WITHIN_PHASE + NO_ANNUAL_CONFLICT	auditAssignmentGuard (all CanInspectAudit checks)
CAN_SELF_ASSIGN	REQUIRE_ACTIVE_INSPECTOR + STRICT_COI + NO_SUPERVISOR_CONFLICT + NO_ANNUAL_CONFLICT + assign:self + NO_DOUBLE_BOOKING	schedule.assign (self-assignment, including to Pending audits with null date). DATE_WITHIN_PHASE is excluded — date is validated at pick time via schedule.set_date, not re-checked at assignment.
CAN_ASSIGN_OTHER_INSPECTOR	Actor must hold assign:others (Admin only); target inspector passes CAN_INSPECT_AUDIT_POLICIES for that audit	Admin assigning inspectors cross-department

Structural Policies

Policy	Description
COORDINATOR_DEPT_SCOPE	Coordinators can only act within their own department (Admin bypasses)
CAN_UPDATE_USER	Self-update always allowed; updating others requires manage:users

CAN_ASSIGN_OTHERS	Requires assign:others capability (Admin only)
SLOT_OWNER_OR_PRIVILEGED	Only the assigned slot owner or a privileged role (Supervisor/Coordinator/Admin) may unassign
ASSIGNED_AUDITOR_ONLY	Only the auditor assigned to the slot may upload the inspection report
VALID_STATUS_TRANSITION	Status changes must follow allowed transitions: open → assigned → in_progress → submitted → reviewed → closed. Arbitrary jumps are denied. Admin may override with system:admin capability — override must be logged with auditLogReason
REQUIRE_CAPABILITY(cap)	Generic factory — denies unless user holds a specific capability string

8. Data Model

User Record (relevant fields)

Field	Type	Purpose
roles	string[] (JSON)	Administrative role hierarchy: ["Admin"], ["Coordinator"], ["Supervisor"], ["Guest"]
qualifications	string[] (JSON)	Other operational tags (if any). Inspector is derived from certificationExpiry, NOT stored here.
certificationExpiry	string (ISO date)	Institutional certificate expiry; required by REQUIRE_ACTIVE_INSPECTOR to activate inspection actions
departmentId	string	User's home department (for COI checks)

Evaluation Context (per-request)

Field	Source	Purpose
targetDepartmentId	Audit's department_id	COI: compare against user's department
supervisorIds	Audit's supervisor_id (comma-separated)	Supervisor conflict check
scheduleDate	Audit schedule date	Date being assigned or updated; used by DATE_WITHIN_PHASE and NO_ANNUAL_CONFLICT
phaseId	Selected audit phase	Identifies Phase 1 / Phase 2 / Phase 3
dateInAnyPhase	Pre-computed by handler	True if scheduleDate falls within ANY configured phase boundary; used by DATE_WITHIN_PHASE
scheduleStatus	Audit's current slot status	Double-booking prevention
currentStatus	Current schedule status value	Used by VALID_STATUS_TRANSITION to validate allowed transitions
nextStatus	Target status to transition to	Used by VALID_STATUS_TRANSITION to validate allowed transitions

currentScheduleId	Current schedule record ID (if updating)	Excluded from NO_ANNUAL_CONFLICT to prevent self-conflict on edit
currentAuditId	Current audit record ID (if updating)	Alternative identifier excluded from NO_ANNUAL_CONFLICT when conflict check uses audit records
auditLogReason	Request body / admin override form	Required when system:admin overrides an invalid status transition; written to audit log
hasAnnualConflict	DB query (checkLocationYearConflict)	Annual inspection limit for scheduleDate's calendar year

9. Key Design Principles

1. **Roles are hierarchical.** Higher roles inherit all lower-role capabilities.
2. **Qualifications are orthogonal.** Inspector is a certificate-derived status, never a role — derived from valid `certificationExpiry`, NOT stored in `qualifications[]`. Other qualification tags (if any) go in `qualifications[]`.
3. **PBAC unions capabilities.** `deriveCapabilities() = deriveRoleCapabilities() ∪ deriveQualificationCapabilities()`.
4. **Policies are pure functions.** Each returns `{ allowed, reason? }`; first DENY short-circuits.
5. **STRICT_COI has no exemptions.** Even Admins cannot audit their own department.
6. **Never check role strings in UI code.** Always use `hasCapability(user, 'system:admin')`.
7. **Avoid role explosion.** Store `{ role: "Coordinator" }`, never `"Coordinator+Inspector"`. Inspector status comes from certificate validity, not the role or qualifications array.